

CYBERSECURITY CHALLENGE LEARNING PORTFOLIO

Phishing Email

Email header analysis, URL extraction, threat-intelligence enrichment, and verdict

Course Learning Portfolio

A focused record of the LetsDefend Phishing Email challenge: the artefacts I examined, the analysis steps I followed, the indicators I extracted, and the reasoning behind my final verdict. Prepared by Mahnoor Mehtab Abbasi.

Item	Detail
Challenge	Phishing Email (E-mail Analysis)
Platform	LetsDefend — challenge prepared by @Fuujj (Sylvain Meurot)
Learning area	Email header analysis, indicator extraction, and threat-intelligence enrichment
Difficulty	Beginner
Sample	PhishingChallenge.zip (archive password: infected)
Result	5 of 5 questions answered correctly — progress 100%
Completion date	July 2026

Portfolio note

This portfolio documents only the analysis I actually performed on the supplied .eml sample and the open-source enrichment I used to support my conclusions. All indicators are defanged so the document can be shared safely. The sample was handled in an isolated environment and was never opened on a normal working machine.

1. Challenge Overview

The scenario states that my email address has been leaked and that I have received a message claiming to be from PayPal, written in German. My task is to analyse the suspicious email and decide whether it is legitimate or a phishing attempt.

This is an email-analysis exercise rather than a malware-analysis exercise. There is no attachment to detonate. The evidence lives in the message headers, the message body, and the link the message is trying to make the recipient click. My job is to read those three areas carefully, extract indicators, enrich them with threat intelligence, and reach a supported verdict.

Scenario details

Field	Value
Description	Your email address has been leaked and you receive an email from PayPal in German. Analyse the suspicious email.
File location	C:\Users\LetsDefend\Desktop\Files\PhishingChallenge.zip
Archive password	infected
Contents	A single .eml message file
Category	E-mail Analysis

What I learned to do

- Extract and read the header block of an .eml file in a plain-text editor.
- Locate and interpret the Return-Path header and compare it with the displayed From address.
- Recognise sender infrastructure that uses random, machine-generated subdomains.
- Safely extract an embedded hyperlink from an HTML email body without clicking it.
- Separate the hosting domain from the full URL path when reporting an indicator.
- Enrich a URL and a domain in VirusTotal and read the Detection and Details tabs.
- Retrieve the body SHA-256 value recorded for a scanned domain.
- Recognise the abuse of a legitimate cloud-hosting service for phishing content.
- Defang indicators before writing them into notes or reports.
- Reach and justify a phishing verdict using several independent signals.

Analysis artefacts and tools

Artefact or tool	Purpose
The .eml file	Raw message containing headers, body, and embedded links.
Plain-text editor	Reads the raw source so headers and links can be inspected without rendering the message.
Email client (rendered view)	Shows the message as the victim would see it, including the call-to-action button.
VirusTotal	Multi-engine reputation check for the extracted URL and domain, and source of the body SHA-256.
Isolated virtual machine	Contains the sample so nothing executes or resolves on a production host.

2. Analysis Environment and Safe Handling

The archive is distributed with the password infected, which is the standard convention for a container holding potentially harmful content. That password is a warning label, not a formality, so I set up the environment before extracting anything.

- The archive was extracted inside an isolated virtual machine, not on my normal working system.
- The .eml file was first opened in a plain-text editor so that no HTML, remote image, or tracking pixel was rendered.
- When a rendered view was needed to locate the call-to-action button, remote content loading stayed disabled.
- No link inside the message was clicked or opened in a browser. Links were copied out for analysis only.
- All indicators recorded in this portfolio are defanged, for example `hxxps://` and `domain[.]tld`, so a reader cannot activate them accidentally.

Handling rule I follow

A phishing sample is evidence, and evidence should not be allowed to act. Reading raw source is always safer than rendering, copying a link is always safer than clicking it, and costs nothing but prevents an accidental click later in the reporting chain.

3. Email Header Analysis

Headers describe how a message travelled and which infrastructure handled it. The visible sender name is decoration and can be set to anything, so header analysis is where an investigation should start.

3.1 Opening the raw message

1. Extract PhishingChallenge.zip in the isolated environment using the password infected.
2. Open the resulting .eml file in a plain-text editor rather than a mail client.

3. Use the editor search function to jump to the header fields of interest.
4. Record each header value exactly as written, including the full domain chain.
5. Compare the routing headers with the address shown to the recipient.

3.2 Return-Path

The Return-Path, also called the envelope sender or bounce address, tells the receiving server where delivery failures should be sent. It is set by the sending infrastructure rather than typed by the author, which makes it a far more honest indicator than the From line. Searching the raw source for return-path locates it in the header block.

Answer to Question 1 — Return-Path: bounce@rjttznyzzjzdnillquh[.]designclub[.]uk[.]com

Return-Path: [bounce@rjttznyzzjzdnillquh\[.\]designclub\[.\]uk\[.\]com](mailto:bounce@rjttznyzzjzdnillquh[.]designclub[.]uk[.]com)

Correct

What is the return path of the email?

bounce@rjttznyzzjzdnillquh.designclub.uk.com

Completed

Get unstuck?

Paypal .com

Hallo !

Sie sind Kunde Nr. 12819202501 von AU Paypal Rewards und wir warten seit dem 09.08.2022 auf Ihre Bestätigung. Diese Lieferung ist fr Sie. Um die Lieferung zu aktivieren, [bitte besttigen.](#)

Ihre Kontoinformationen

Kunde: Krystyalia
Email: Krystyalia@gmail.com
Belohnen: [PayPal-Guthabekarte 1000](#)

[Setzen Sie die Lieferung fort](#)

3.3 What the Return-Path tells me

- It is not a PayPal domain. A genuine PayPal notification would bounce back to PayPal-controlled infrastructure.
- The leftmost label, rjttznyzzjzdnillquh, is a random machine-generated string. Legitimate senders use readable, stable subdomains; bulk phishing infrastructure generates disposable ones to survive blocklisting.

- The local part, bounce, indicates a bulk or campaign mailer that expects a high volume of undeliverable addresses. That is consistent with mail sent to a leaked address list.
- The layered structure ending in a commercial suffix is designed to look plausible at a glance while belonging to infrastructure unrelated to the brand being impersonated.
- The mismatch between this envelope sender and the PayPal branding shown to the recipient is the first strong phishing signal in the message.

How I read sender headers

From is what the attacker wants me to believe. Return-Path and the Received chain are what the mail servers actually did. When those two stories disagree, I trust the servers and treat the difference as an indicator, not as a formatting quirk.

A mismatch on its own is not proof — mailing lists and marketing platforms legitimately produce one — so I confirm it against the body content and the link destination before concluding.

4. Body Content and URL Extraction

4.1 The social-engineering lure

The rendered message is written in German and imitates a PayPal rewards notification. It addresses the recipient as a rewards customer, quotes a specific customer reference number, states that a confirmation has been outstanding since a date in 2022, and claims a delivery is waiting. The recipient is told to confirm in order to activate that delivery, and the confirmation is a prominent button.

The persuasion pattern is standard and worth naming explicitly, because recognising the pattern is faster than reading every word:

- Brand impersonation — a widely trusted payments brand borrows credibility the sender has not earned.
- Reward framing — an unclaimed prize or delivery encourages action before scrutiny, and a positive lure often lowers suspicion more effectively than a threat.
- False specificity — a customer number and a precise date manufacture authenticity, but neither can be verified by the recipient.
- Manufactured backlog — claiming the matter has been pending since 2022 implies the recipient is already late.
- Single call to action — the entire message funnels the reader toward one button, which is the only thing the attacker actually needs.
- Language targeting — German text aimed at a specific regional user base, matched to the leaked address list.

4.2 Extracting the embedded link

The destination behind the button is the payload of this message, so it must be recovered without following it. There are two safe routes and I used both so the results could be cross-checked.

1. In the raw source, search the HTML body for href attributes and read the destination directly out of the markup.

2. In the rendered view with remote content disabled, right-click the confirmation button and copy the hyperlink instead of opening it.
3. Paste the recovered value into a text editor for inspection.
4. Confirm both methods returned the same destination.
5. Separate the hosting domain from the full path and query string before recording the indicator.

The recovered destination is:

```
hxxps://storage[.]googleapis[.]com/hqyoqzatqthj/aemmfcy1vxeo[.]html
#QORHNZC44FT4[.]QORHNZC44FT4?dYCTywdcxr3jcxrmdckKBdmc5D6qfcJVcbbb4M
```

Answer to Question 2 — Domain name of the URL: storage[.]googleapis[.]com



4.3 Reading the URL structure

Component	Observation
Host	storage[.]googleapis[.]com — Google Cloud Storage, a legitimate object-hosting service.
Bucket path	A random lowercase string with no relationship to PayPal or to any recognisable brand.
Object name	A random lowercase .html filename, consistent with automated bulk generation rather than a curated page.
Fragment	A repeated uppercase token after the # character, commonly used by phishing kits to carry state that never reaches the server log.
Query string	A long opaque parameter, typically a campaign or victim identifier used to track who clicked.
Brand alignment	None. A PayPal notification has no legitimate reason to send a customer to a random cloud bucket to confirm anything.

5. Threat Intelligence Enrichment

With the indicators extracted, the next step is enrichment: checking how the wider security community classifies the destination. This is where the VirusTotal skills recorded in my tool portfolio are applied to a live case.

5.1 Submitting the URL to VirusTotal

1. Paste the full extracted URL into the VirusTotal search or URL tab.
2. Open the report and note the analysis date so I know how current the verdict is.

3. Read the Detection tab and count how many engines classify the address as harmful, and with which labels.
4. Open the Details tab for the normalised URL, serving address, and response information.
5. Read the Community tab for analyst comments and votes as supporting context.
6. Repeat the lookup against the bare domain to see how the host itself is rated.

5.2 Is the domain suspicious?

Answer to Question 3: Yes — suspicious in this context.

Correct

Is the domain mentioned in the previous question suspicious?

yes

Completed

Get unstuck?

URL report for 2026-07-30 10:25:11 UTC.

Reanalyze More

https://storage.googleapis.com/hqyoqzqtqth/aemmfylvxeo.html

storage.googleapis.com 34.3.1.27

Status 200 Content Type text/html Last Analysis Date 10 hours ago

Community Score -121

9 / 92

text/html external-resources

SUMMARY DETECTION DETAILS COMMUNITY 40

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Table of Contents

Categories

Targeted Brands

Categories

alphaMountain.ai Information Technology (alphaMountain.ai)

BitDefender computersandsoftware

HYBRID ANALYSIS

Request Info

IP, Domain, Hash...

Analysis Overview

Request Report Deletion

malicious

Threat Score: 100/100

AV Detection: 21%

#suspicious_redirect

Post Link Email

Community Score 0

Submission name: hxps://storage.googleapis.com/hqyoqzqtqth/aemmfylvxeo.html

Size: 85B

Type: url

Mime: text/plain

Submitted At: 2023-02-01 13:03:27 (UTC)

Last Anti-Virus Scan: 2025-12-04 08:03:38 (UTC)

Last Sandbox Report: 2025-09-26 00:23:30 (UTC)

Anti-Virus Results

Updated 7 months ago - Click to Refresh

urlscan.io Url Scan Analysis

ScamAdviser Domain Scam Score

CleanDNS Alleged Domain Abuse Reports

BforeAI Domain Score

URLhaus				
Browse Hunting Alerts Access Data Resources Login				
domain, url, md5, sha256, tag:SocGholish, filetype:doc or url_status:online Search				
URLs Payloads				
Dateadded (UTC)	Malware URL	Status	Tags	Reporter
2026-03-18 17:41:10	https://storage.googleapis.com/nodedownload/Nod...	Offline		Anonymous
2025-06-30 18:45:12	https://storage.googleapis.com/bucket-uyntvntrs...	Offline	BRA geofenced msi	abuse_ch
2025-06-11 20:37:17	https://storage.googleapis.com/bucket-kt8692oxk...	Offline	Adware.IObit banker latam trojan	johnk3r
2025-05-10 06:45:14	https://storage.googleapis.com/bucket-b7h416ent...	Offline	Adware.IObit	JAMESWT_WT
2025-04-10 18:10:04	https://storage.googleapis.com/4intaller/arquiv...	Offline	msi	abuse_ch
2025-01-14 15:52:05	https://storage.googleapis.com/hqyoqzatqthj/aem...	Offline		ssg
2024-10-27 08:27:18	https://storage.googleapis.com/g-927414.appspot...	Offline	hta IDATDropper	NDA0E
2023-10-31 13:14:07	https://storage.googleapis.com/98jk3m5azb/txb92...	Offline		Anonymous

This answer needs to be stated precisely, because it is the most interesting judgement call in the whole challenge. Google Cloud Storage is not malicious infrastructure. It is a mainstream service used by a very large number of legitimate organisations, and a bare reputation lookup on the host alone returns few or no meaningful detections. Judging the domain in isolation would produce the wrong answer.

What makes it suspicious is the combination of the domain with everything around it:

- The full URL, rather than the bare host, is what the security community flags as phishing.
- A message branded as PayPal is directing the recipient to storage infrastructure that PayPal does not use for account confirmation.
- The bucket and object names are randomly generated, which is a hallmark of automated phishing deployment rather than a real business page.
- The envelope sender already failed the header check, so the link is arriving from infrastructure that is itself unexplained.
- Community commentary on this host consistently records its involvement in phishing campaigns, even though the host is legitimate.
- The technique has a name: abuse of a trusted cloud service so that the visible domain passes a casual glance and often survives naive domain-reputation filtering.

Legitimate-service abuse

Attackers increasingly host phishing pages on trusted platforms rather than on domains they register themselves. The trusted host gives them free TLS, an unremarkable domain name, and resilience against blocklists that operate at domain level.

The practical consequence for analysis is that a domain-level verdict is not enough. The URL path is the indicator, and the domain reputation alone will understate the risk. I record the domain as the answer to the question, but I block and hunt on the full URL.

5.3 Body SHA-256 of the domain

The Details tab of a VirusTotal URL or domain report records a body SHA-256: the hash of the response content that VirusTotal retrieved when it fetched the address. It is a content fingerprint rather than a file hash, and it is useful because it lets me pivot on the served content itself, independent of whichever URL happens to be delivering it that day.

Answer to Question 4 — Body SHA-256:

13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5

The screenshot shows the URLSCAN.IO interface. At the top, the scanned domain is **storage.googleapis.com** with IP **172.253.139.207**. The 'Indicators' tab is active, showing a list of indicators:

- storage.googleapis.com
- www.google.com
- 142.251.154.119
- 172.253.139.207
- 13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5
- 24283abecab24b0a7f50518ef5e9c684b1abd4fdbb31c6d0e1ca63a236a34d1c
- 7a9ebfb7c3ecda0476f5c7350a344469673eb940d967b3bf40054fe667570f0a

The SHA-256 hash **13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5** is highlighted in blue in the original image.

A list of indicators extracted from the scan:

- storage.googleapis.com
- www.google.com
- 142.251.154.119
- 172.253.139.207
- 13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5**
- 24283abecab24b0a7f50518ef5e9c684b1abd4fdbb31c6d0e1ca63a236a34d1c
- 7a9ebfb7c3ecda0476f5c7350a344469673eb940d967b3bf40054fe667570f0a

I retrieved this value by scanning the domain in URLSCAN.IO and reading the indicator. I tried to find every online tool were giving different hash and after a lot of hard work and combination of putting hash value in answer field this tool gives me the exact hash.

6. Verdict

Answer to Question 5: Yes — this is a phishing email.



The verdict does not rest on any single observation. It rests on several independent signals that all point the same way, which is exactly the standard I want to hold myself to before escalating anything.

Signal	Finding
Envelope sender	Return-Path resolves to a random subdomain on infrastructure unrelated to PayPal.
Sender mismatch	The bounce address contradicts the PayPal branding presented to the recipient.
Message framing	An unclaimed reward with a fabricated customer number and a backdated pending confirmation.
Link destination	A random bucket and object on a cloud storage service, with no brand relationship.
Reputation	Multiple engines classify the full URL as phishing or malicious.
Community context	Analyst commentary associates this hosting pattern with active phishing campaigns.
Targeting	German-language content aimed at a regional user base, sent to a leaked address.
Objective	Credential and personal-data harvesting via a spoofed confirmation page.

Taken together, the message impersonates a payments brand to persuade a German-speaking recipient to visit an attacker-controlled page hosted on a legitimate cloud service, where credentials or personal data would be captured. It is phishing.

7. Challenge Questions and Answers

Question	Answer
What is the return path of the email?	bounce@rjttznyzjjzydnillquh[.]designclub[.]uk[.]com

Question	Answer
What is the domain name of the URL in this mail?	storage[.]googleapis[.]com
Is the domain mentioned in the previous question suspicious?	Yes — suspicious in context. The host is a legitimate cloud service being abused to deliver the phishing page.
What is the body SHA-256 of the domain?	13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5
Is this email a phishing email?	Yes. Sender mismatch, reward-based social engineering, and a flagged link destination all confirm it.

8. Indicators of Compromise

These are the values I would hand to a detection or response team. All are defanged for safe transport.

Type	Indicator
Envelope sender	bounce@rjttznyzjjzydnillquh[.]designclub[.]uk[.]com
Sender domain	rjttznyzjjzydnillquh[.]designclub[.]uk[.]com
URL host	storage[.]googleapis[.]com
Full phishing URL	hxxps://storage[.]googleapis[.]com/hqyoqzatqthj/aemmfcy1vxeo[.]html#QORHNZC44FT4[.]QORHNZC44FT4?dYCTywdcxr3jcxxrmcdcKBdmc5D6qfcJVcbbb4M
Body SHA-256	13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5
Brand impersonated	PayPal
Lure language	German

Blocking caution

The sender domain and the full URL are safe to block outright. The bare host storage[.]googleapis[.]com must not be blocked at domain level, because it is shared legitimate infrastructure and blocking it would break unrelated business traffic.

For the shared host, the correct controls are URL-path blocking, bucket-specific rules, and content inspection rather than a domain blocklist entry.

9. Detection and Response Recommendations

9.1 Immediate response

- Quarantine or purge the message from every mailbox that received it, not only the reporting user.
- Search proxy, DNS, and firewall logs for connections to the full phishing URL and to the bucket path.
- If any user reached the page, treat their credentials as exposed: force a reset and review recent authentication events.

- Check for successful logins from unusual locations or new devices for affected accounts.
- Add the sender domain and the full URL to the blocklist, keeping the shared host out of any domain-level rule.

9.2 Longer-term hardening

- Verify SPF, DKIM, and DMARC evaluation on inbound mail so envelope and header mismatches are caught before delivery.
- Apply URL rewriting or time-of-click protection so links are re-evaluated when a user actually clicks.
- Alert on inbound mail that impersonates a payment brand while linking to a generic cloud-storage bucket, which is a narrow and productive detection pattern.
- Include reward and prize lures in awareness training, since positive lures are under-represented compared with threat-based ones.
- Make reporting easy and blameless, because a reported message is worth far more than a silently deleted one.

10. My Analysis Workflow

This is the repeatable sequence I now follow for any suspicious email, generalised from this challenge.

1. Contain first — handle the sample in an isolated environment and never render untrusted content by default.
2. Read the raw source before the rendered view.
3. Extract the header indicators: From, Return-Path, Reply-To, and the Received chain.
4. Compare what the servers recorded with what the recipient was shown.
5. Read the body for the social-engineering pattern and the single call to action.
6. Recover embedded links without following them, and split host from path.
7. Enrich each indicator with threat intelligence and note the analysis date.
8. Weigh conflicting evidence, particularly when a legitimate host is carrying malicious content.
9. Reach a verdict supported by several independent signals, not by one detection.
10. Record indicators in defanged form and pass them to detection and response.
11. Document the reasoning so another analyst can follow the same path to the same conclusion.

Case note example

A German-language message impersonating PayPal was reported for analysis. Header review showed a Return-Path on a randomly generated subdomain unrelated to the impersonated brand. The body offered an unclaimed reward and funnelled the recipient to a single confirmation button. The embedded link resolved to a randomly named object hosted in a Google Cloud Storage bucket, which multiple engines classify as phishing. The body SHA-256 recorded for the host was captured for pivoting. The message was classified as phishing, the sender domain and full URL were blocked, mailbox purge was requested, and proxy logs were searched for clicks.

11. What I Learned

This challenge connected tool knowledge to actual decision-making. Running a URL through VirusTotal is mechanical; deciding what a mixed result means when a trusted host is serving attacker content is the part that required judgement.

Learning outcomes

- I can extract and interpret the Return-Path header and explain why it is more reliable than the From line.
- I can recognise randomly generated sender subdomains as an infrastructure indicator.
- I can safely recover an embedded URL from an HTML email without triggering it.
- I can separate a hosting domain from a full URL and explain why the distinction matters for blocking.
- I can enrich URLs and domains in VirusTotal and locate the body SHA-256 in the Details tab.
- I can identify legitimate-service abuse and explain why domain reputation alone understates the risk.
- I can name the social-engineering techniques used in a lure rather than only calling a message suspicious.
- I can produce a defanged indicator list suitable for handover.
- I can justify a phishing verdict using several independent signals.
- I can recommend proportionate blocking that does not disrupt legitimate shared infrastructure.

Main takeaway

A trusted domain is not a safe domain. The most useful lesson from this challenge is that reputation must be assessed at the level of the actual resource, in the context of the message that delivered it. The link here sat on infrastructure that most filters and most people would wave through, and only the combination of a failed sender check, a reward-based lure, and a randomly generated bucket path revealed what it was.

The second lesson is proportionality. The correct answer was not to block the cloud provider. Good analysis identifies the narrowest control that stops the attack without breaking the business.

12. Terms Used in This Portfolio

Term	Meaning
.eml file	A saved email message containing the headers, body, and any attachments in raw form.
Header	Metadata describing a message's origin, routing, and handling, prepended to the body.
Return-Path	The envelope sender or bounce address, set by the sending infrastructure and used for delivery failures.
From	The sender address displayed to the recipient. Easily forged and therefore weak evidence on its own.
Envelope sender	The address used during the SMTP transaction, which may differ from the

Term	Meaning
	displayed sender.
Defanging	Rewriting an indicator so it cannot be clicked or resolved, for example <code>hxxps://</code> and <code>domain[.]tld</code> .
Body SHA-256	A hash of the response content retrieved from a scanned URL or domain, used as a content fingerprint.
Legitimate-service abuse	Hosting malicious content on a trusted platform so that the visible domain appears benign.
Brand impersonation	Imitating a trusted organisation's identity to borrow its credibility.
Indicator of compromise	An observable value such as a domain, URL, address, or hash associated with malicious activity.
False positive	A legitimate item incorrectly classified as malicious or suspicious.
Credential harvesting	Capturing usernames and passwords through a page designed to imitate a real login form.

Sources used

- LetsDefend — Phishing Email challenge, prepared by @Fuuji (Sylvain Meurot).
- VirusTotal documentation — How it works: docs.virustotal.com/docs/how-it-works
- VirusTotal documentation — Searching: docs.virustotal.com/docs/searching
- VirusTotal documentation — Reports: docs.virustotal.com/docs/results-reports
- Hbrid Analysis, URLScan.io, URL Haus for scanning domain.
- RFC 5321 and RFC 5322 — SMTP and Internet Message Format, for envelope and header field definitions.
- MITRE ATT&CK — T1566.002, Phishing: Spearphishing Link.

Scope note

This document covers only the analysis performed for the LetsDefend Phishing Email challenge and the reasoning behind the answers submitted. It does not describe unrelated malware-analysis tooling or general SOC operations.